

一种基于格的轻量级多因素认证密钥交换协议^{*}

原煜博^{1a}, 肖为恩^{1a}, 吴倩倩^{1b}, 黄鑫^{1b,2,3†}

(1. 太原理工大学 a. 计算机科学与技术学院(大数据学院); b. 人工智能学院, 山西 晋中 030600; 2. 广西师范大学 广西多源信息挖掘与安全重点实验室, 广西 桂林 541004; 3. 浙江大学 浙江大学区块链与数据安全全国重点实验室, 杭州 310000)

摘要: 随着量子计算的快速发展,物联网(Internet of Things, IoT)场景中面临严峻的认证安全挑战。现有认证密钥交换(authentication key exchange, AKE)协议大多基于离散对数或大整数分解等数学难题构建,不仅易受到量子攻击,还存在较高的计算与通信开销,难以满足资源受限的物联网设备的安全需求。为此提出了一种基于格的轻量级多因素认证密钥交换协议,该协议利用环上带误差学习(ring learning with errors, RLWE)问题构建,具备抗量子攻击能力。同时,在格密码体制基础上融合口令、生物特征与智能卡三种认证因素,实现了多因素认证机制,以适应物联网高安全场景的需求。方案通过在随机响应(real-or-random, ROR)模型下的形式化安全分析及非形式化安全分析证明了其安全性,表明能够抵抗包括信号泄露攻击在内的多种已知攻击。实验结果表明,相较于其他同类方案,该方案具备更低的计算开销及一定的通信开销优势,适用于资源受限物联网设备。

关键词: 物联网; 环上带误差学习; 格密码; 多因素认证密钥交换协议

中图分类号: TP309 **文献标志码:** A **文章编号:** 1001-3695(2026)07-030-2164-09

doi: 10.19734/j.issn.1001-3695.2025.08.0441

Lightweight multi-factor authentication key exchange protocol based on lattice cryptography

Yuan Yubo^{1a}, Xiao Weien^{1a}, Wu Qianqian^{1b}, Huang Xin^{1b,2,3†}

(1. a. College of Computer Science and Technology (College of Data Science), b. College of Artificial Intelligence, Taiyuan University of Technology, Jinzhong Shanxi 030600, China; 2. Guangxi Key Lab of Multi-Source Information Mining & Security, Guangxi Normal University, Guilin Guangxi 541004, China; 3. The State Key Laboratory of Blockchain and Data Security, Zhejiang University, Hangzhou 310000, China)

Abstract: With the rapid advancement of quantum computing, the Internet of Things (IoT) is facing severe authentication-security challenges. Most existing authentication key exchange (AKE) protocols rested on mathematical hard problems such as discrete logarithms or large integer factorization; these choices proved quantum-vulnerable and imposed heavy computational and communication costs that disqualified the protocols from resource-constrained IoT devices. To overcome these drawbacks, this paper proposed a lattice-based lightweight multi-factor AKE protocol, constructed it from the ring learning with errors (RLWE) problem to resist quantum attacks, and integrated passwords, biometrics and smart cards into the lattice cryptosystem to realise a multi-factor authentication mechanism that satisfies the high-security demands of IoT environments. The scheme's security was formally analysed in the real-or-random (ROR) model and was informally evaluated against known attacks; the analysis showed resistance to signal-leakage and other known attacks. Experimental results show that, compared with similar schemes, the proposed protocol incurs lower computational costs and enjoys reduced communication overhead, making it well suited to resource-constrained IoT devices.

Key words: Internet of Things; ring learning with errors problem; lattice-based cryptosystem; multi-factor authentication key exchange protocol

0 引言

IoT 通过网络连接实现信息的高效传输,促进了设备之间的数据集成^[1]。近年来,随着医疗物联网、工业物联网、车辆物联网以及无线传感器网络等应用的快速发展,引领了多个行业的创新与变革。

在 IoT 应用中,用户设备与服务基础设施之间会进行频繁的应用层数据传输,例如传输命令和用户状态信息。然而,设备间的通信面临着窃听和伪造等安全威胁。攻击者可能窃取

通信中的敏感信息,甚至冒充合法实体进行恶意通信^[2,3],这些攻击对用户信息和财产造成了严重威胁。为应对这些挑战,认证密钥交换(AKE)协议^[4-9]成为确保 IoT 安全通信的关键技术。鉴于物联网特定场景对高安全性的需求,且生物识别技术在物联网设备中的广泛应用,传统的 AKE 协议^[10-15]已将生物特征作为额外认证因素,从而提高安全性。生物特征(如指纹、面部识别和虹膜)作为个体的独特生理特征,通常在与口令和智能卡联合使用时,构成多因素 AKE 协议。与单因素和双因素 AKE 协议相比,多因素 AKE 协议在安全性方面具有明显优势。因此基于多因素的 AKE 协议已成为热门研究方向。

收稿日期: 2025-08-19; **修回日期:** 2025-11-14 **基金项目:** 山西省科技成果转化引导专项资助项目(202204021301043);广西多源信息挖掘与安全重点实验室开放基金资助项目(MIMS24-09);浙江大学区块链与数据安全全国重点实验室开放课题资助项目(A2516)

作者简介: 原煜博(2000—),男,山西运城人,硕士研究生,CCF 会员,主要研究方向为信息安全;肖为恩(1997—),男,浙江湖州人,博士研究生,主要研究方向为信息安全;吴倩倩(2000—),女,山西临汾人,硕士研究生,主要研究方向为信息安全;黄鑫(1982—),男(通信作者),山西忻州人,教授,博导,博士,主要研究方向为信息安全、区块链、物联网。

2022年, Qiu等人^[16]利用“模糊验证器”技术构造了一个模糊口令验证器, 然后结合“蜜语”的概念设计了一个基于扩展混沌映射的轻量级多因素 AKE 协议, 该协议能够有效抵抗口令猜测攻击。同年, Rafique等人^[17]提出了一种用于工业物联网场景的多因素 AKE 协议, 该协议结合了对称加密、异或加密和哈希算法, 以支持合法用户与传感器节点之间的远程认证。2024年, Han等人^[18]指出 Rafique等人^[17]的协议容易受到内部攻击和已知会话特定临时信息攻击, 且无法提供前向安全性。随后提出了一种增强的多因素 AKE 协议, 以抵抗这些攻击。同年, Zou等人^[19]提出了一种面向工业物联网智能工厂的鲁棒多因素 AKE 协议, 该协议能够实现安全性和效率之间的平衡。2025年, 杨昱坤等人^[20]通过利用生物哈希技术和椭圆曲线加密, 设计了一种面向物联网场景的动态多因素 AKE 协议, 确保了用户在登录过程中的匿名性和不可链接性。然而, 现有的大多数 AKE 协议(包括上述的多因素 AKE 协议)依赖于经典假设, 例如离散对数问题, 一旦大规模量子计算机投入使用, 其安全性将受到严重威胁。

近年来, 基于格的密码体制由于其可证明的安全性、较低的计算和通信开销, 被广泛用于构造抗量子攻击的 AKE 协议^[21]。2018年, Gao等人^[22]构建了一个基于 RLWE 的随机 AKE 协议, 通过在两端增加额外的临时公共误差项, 以抵抗信号泄露攻击, 支持密钥重用。同年, Feng等人^[23]提出了一种基于理想格的匿名口令 AKE 协议, 用于客户端-服务器认证。2020年, Dabra等人^[24]指出 Feng等人^[23]方案易受信号泄露、欺骗和操纵攻击, 随后提出了 LBA-PAKE 协议以抵抗这些攻击, 同时实现匿名性、密钥重用和前向安全性。2021年, Wang等人^[25]考虑到协议对资源受限设备的适用性, 提出了 Quantum2FA, 一种基于 NewHope 协议^[26]的轻量级后量子双因素 AKE 协议, 该协议很好地平衡了安全性与效率。然而, 在后续研究中 Qin等人^[27]发现 Quantum2FA 的认证和密钥保护机制存在结构缺陷, 使其易受信号泄露攻击, 这可能导致服务器的静态密钥暴露。2022年, Ding等人^[28]发现, 当主密钥被重用时, LBA-PAKE^[24]协议仍然易受信号泄露攻击。他们提出了两项增强措施以抵抗此类攻击, 且不产生额外开销。2023年, Dharminder等人^[29]提出了一种基于格的 AKE 协议, 该协议基于 RLWE 问题, 并利用错误调制技术以实现相互认证。2024年, Pursharthi等人^[30]指出 Ding等人^[28]的改进缺乏强认证能力且易受内部攻击。为解决此问题, 他们提出了一种基于格的生物识别 AKE 协议。同年, Chen等人^[31]提出了一种基于 MLWE 假设具有隐私保护的多因素 AKE 协议, 以增强支持云服务物联网的量子安全性。然而该协议在两端采用了大量耗时的多项式乘法, 增加了资源受限物联网设备的计算开销。Liu等人^[32]面向车联网场景提出了一种基于格的鲁棒条件隐私保护的 AKE 协议, 该协议实现车辆上的匿名认证, 并采用小整数解问题来抵御量子攻击。2025年, 倪亮等人^[33]提出了一种基于身份的后量子匿名认证 AKE 协议, 并证明其在改进的 ID-BJM 模型下是安全的。最近, Liu等人^[34]提出了一种基于格的可追溯的鲁棒 AKE 协议, 以实现鲁棒的条件可追溯性以及公钥的不可链接性, 但其通信开销以及计算开销较大。

综上, 目前现有的基于格的多因素 AKE 协议研究较少, 其他基于格的单因素或双因素 AKE 协议易遭受信号泄露攻击, 而为了抵抗这类攻击, 通常会在通信双方添加额外的多项式乘法, 以保证安全性, 但是大量的多项式乘法往往会带来高昂的计算成本, 尤其对于一些资源受限的物联网设备, 这些设备的计算资源以及内存通常较小, 过多耗时的加密操作会加重它们的负担, 因此这些基于格的 AKE 协议不能直接构造多因素 AKE 协议以在物联网设备中部署。针对这一问题, 利用 RLWE

问题的难解性, 提出了一种基于格的轻量级多因素 AKE 协议, 旨在应对量子计算带来的安全挑战。该方案在格的密码体制下结合口令、智能卡和生物特征等认证因素, 构建轻量级的多因素认证方案, 以满足资源受限设备的量子安全需求, 并为物联网带来了更高级别的安全保障。具体贡献如下:

a) 提出了一种基于格的轻量级多因素 AKE 协议, 该协议建立在 RLWE 问题的难解性基础上。此外, 在格密码体制上融合生物特征、口令和智能卡三种认证因素实现了多因素认证。该协议在保证安全性的同时, 降低了用户端设备耗时的多项式乘法操作, 以适用于资源受限的物联网设备。

b) 基于 ROR 模型形式化分析了该协议的可证明安全性, 并提供了一系列关于该协议的非形式化安全分析。分析表明所提协议实现了用户的匿名性、不可链接性和相互认证等, 并且能够有效抵御信号泄露、重放、冒充等多种恶意攻击且满足三因素安全。

c) 提供了与同类协议的详细性能比较, 包括计算开销、通信开销和存储开销。结果表明, 与同类协议相比, 所提协议能够实现更少的计算开销和更高的安全性。

1 预备知识

1.1 RLWE

RLWE 的基本术语和概念将涵盖在这一部分, 并且通过一些引理来证明所提出方法的正确性。

RLWE 问题是学习误差问题(learning with errors, LWE)的一个著名变体。它将 LWE 中的内积替换为多项式乘积, 本文设定整数集合为 Z , 设 $f(m) = m^i + 1 \in Z[m]$, 其中参数 $i \in Z$ 且 i 是 2 的幂, 从而保证 $f(m)$ 在有理数域上不可约。定义 $R = Z[m]/f(m)$ 为多项式环, 其元素为模 $f(m)$ 的整数多项式剩余类。令 $q = 1 \bmod 2n$ 为一个足够大的公共素数模数, 并定义 $R_q = Z_q[m]/f(m)$ 为模 $f(m)$ 和 q 的整数多项式环。 R_q 的元素可以表示为次数小于 n 的多项式, 其系数属于集合 $Z_q = 0, \dots, q-1$ 的标准代表元。取随机元素 $t \in R$, 元素可以表示为 $t = t_0 + t_1 m + t_2 m^2 + \dots + t_{n-1} m^{n-1}$, 设 χ_α 表示给定 $\alpha \in \mathbb{R}^+$ 的离散高斯分布。

引理 1 对于 $a, b \in R$, 下列不等式成立:

$$\|a \cdot b\|_\infty \leq \sqrt{n} \|a\|_2 \|b\|_2 \quad (1)$$

$$\|a \cdot b\|_\infty \leq \sqrt{n} \|a\|_\infty \|b\|_\infty \quad (2)$$

引理 2 此式 $\Pr_{a \leftarrow \chi_\alpha} [\|a\| > \alpha \cdot \sqrt{n}]$ 对所有形如 $\alpha = \omega(\sqrt{\log n})$ 的 α 成立, 其中 $\alpha \in \mathbb{R}^+$ 。

设 $Z_q = \{-(q-1)/2, \dots, (q-1)/2\}$ 且 $F = \{ \lfloor q/4 \rfloor, \dots, \lfloor q/4 \rfloor \} \subset Z_q$ 信号函数 Cha 在 F° 上定义为

$$\text{Cha}(n) = \begin{cases} 0, & n \in F \\ 1, & n \in F \end{cases} \quad \forall n \in Z_q \quad (3)$$

鲁棒提取器 $\psi_2 : Z_q \times \{0, 1\} \rightarrow \{0, 1\}$ 构造为

$\psi_2(m, t') = (m + (t'(q-1))/2) \bmod q \bmod 2$, 其中: $m \in Z_q$ 且 $t' = \text{Cha}(m)$ 。

引理 3 对于给定的 q 和 $m, \varepsilon \in R_q$, 并且 $|\varepsilon| < \frac{q}{8}, n = m + \varepsilon$,

$\psi_2(m, t) = \psi_2(n, t)$ 成立。

对于任何属于环 R_q 的元素

$$u = u_0 + u_1 m + u_2 m^2 + \dots + u_{(n-1)} m^{(n-1)} \quad (4)$$

都可以表示为

$$u = (u_0, u_1, \dots, u_{(n-1)}) \in \{0, 1\}^n \quad (5)$$

对于向量

$$u = (u_0, u_1, \dots, u_{(n-1)}) \quad (6)$$

$$\mathbf{w} = (\mathbf{w}_0, \mathbf{w}_1, \dots, \mathbf{w}_{(n-1)}) \in \{0, 1\}^n \quad (7)$$

应用到 Cha 和 ψ 即:

$$\text{Cha}(\mathbf{u}) = (\text{Cha}(\mathbf{u}_0), \text{Cha}(\mathbf{u}_1), \dots, \text{Cha}(\mathbf{u}_{n-1})) \quad (8)$$

$$\psi_2 = (\psi_2(\mathbf{u}_0, \mathbf{w}_0), \psi_2(\mathbf{u}_1, \mathbf{w}_1), \dots, \psi_2(\mathbf{u}_{n-1}, \mathbf{w}_{n-1})) \quad (9)$$

1.2 系统模型

图 1 展示了本文的系统模型。用户使用手表、手机、智能门锁等物联网智能设备在采集数据后与服务器进行交互时易受到量子攻击,因此在双向认证时融合多种因素进行认证(口令,智能卡,生物特征),为身份认证提供了更强的安全保障。

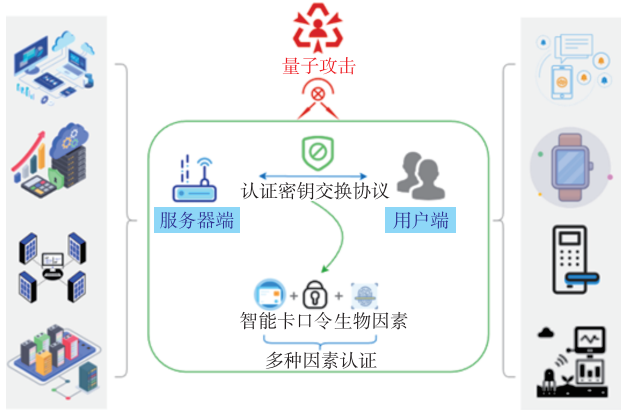


图 1 系统模型
Fig. 1 System model

2 提出的方案

本章将详细描述基于格的轻量级多因素认证密钥交换协议的算法流程,包括初始化阶段、注册和登录认证阶段。符号解释如表 1 所示。

表 1 符号与相应描述

Tab. 1 Symbols and descriptions

符号	描述
U_i	第 i 个用户实例
S_j	第 j 个服务器实例
SC_i	U_i 的智能卡
ID_i	U_i 的 ID
Bio_i	U_i 的生物特征
$H(\cdot)$	哈希函数
a	公共参数 $a \in R_q$
χ_α	离散高斯分布
$s_i, s_j \in R_q$	U_i 和 S_j 的私钥
$\text{Gen}(Bio_i)$	生物密钥提取算法
$\text{REP}(Bio_i^*, \tau_i)$	生物密钥重构算法

2.1 初始化阶段

表 1 中描述了协议使用的所有符号。在提出的加密协议中,参数设置对于在用户 U_i 和服务器 S_j 之间建立安全的通信通道至关重要。这个过程涉及选择和配置将在协议中使用的多种参数,以确保安全性和认证。

详细步骤如下:

S_j 选取一个素数 q ,该素数将用作各种加密操作的基础。此外, S_j 设置 $g = 2^y$,其中 y 是一个正整数($y > 0, y \in \mathbb{Z}$)。

选择一个离散高斯分布 χ_α 和公共参数 $a \in R_q$,另外

U_i 随机采样,令 s_i 为私钥,之后计算公钥 $pk_i = a \cdot s_i + 2 \cdot e_i$ 。

S_j 随机采样,令 s_j 为私钥,之后计算公钥 $pk_j = a \cdot s_j + 2 \cdot e_j$ 。

2.2 注册阶段

在注册阶段,所有用户(U_i)都必须向服务器(S_j)注册并获取身份信息以建立身份验证。

a)为抵抗内部攻击,用户 U_i 仅选择一个 ID_i ,通过安全信

道将其发送给服务器 S_j 。

b)服务器 S_j 收到来自 U_i 的 ID_i 后,计算 $KU_i = H(ID_i \| s_j)$,并将 $\{KU_i, H(\cdot)\}$ 存入一张新的智能卡 SC_i 中,最后将 SC_i 通过安全信道发送给用户 U_i 。

c)用户 U_i 收到从服务器 S_j 发来的智能卡 SC_i 后,输入自己选择的口令 PW_i 和指纹 Bio_i 后,利用生物密钥提取算法计算 $(\sigma_i, \tau_i) = \text{Gen}(Bio_i)$,以及计算参数 $E = H(\sigma_i \| PW_i) \oplus a$, $A_i = KU_i \oplus H(PW_i \| \sigma_i)$ 和 $V_i = H(KU_i \| PW_i \| \sigma_i \| ID_i \| a)$,最后更新智能卡 $SC_i = \{A_i, V_i, E, H(\cdot)\}$,注册过程如图 2 所示。

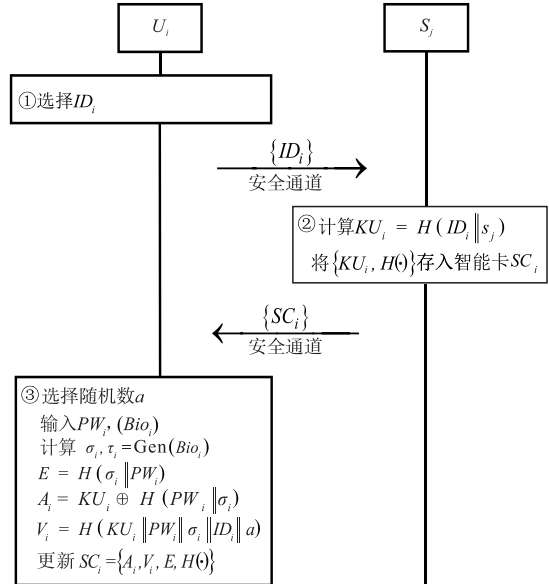


图 2 注册阶段

Fig. 2 Registration phase

2.3 登录和认证阶段

当用户 U_i 成功向服务器 S_j 成功注册后,他可以在需要获取服务时向 S 发送登录认证请求。具体步骤如下:

a)用户 U_i 将智能卡 SC_i 插入读卡器,并向 SC_i 输入 口令 PW_i 、身份标识 ID_i 和生物信息 Bio_i^* ,然后用户 U_i 利用生物密钥重构算法计算 $\sigma_i = \text{REP}(Bio_i^*, \tau_i)$ 以及计算 $KU_i = A_i \oplus H_0(\sigma_i \| PW_i)$ 和 $a = E \oplus H(\sigma_i \| PW_i)$ 。

b)然后智能卡 SC_i 验证 $V_i = H(KU_i \| PW_i \| \sigma_i \| ID_i \| a)$,如果验证失败,智能卡 SC_i 拒绝该登录请求。否则, SC_i 从离散高斯分布 χ_α 中随机采样 $r_i \leftarrow \chi_\alpha$,并计算 $X_u = r_i \cdot pk_i$,利用信号函数计算 $w_i = \text{Cha}(X_u)$,然后计算以下重要参数: $T = \text{mod}_2(X_u, w_i)$, $u_i = r_i + s_i$, $D_{id} = ID_i \oplus T$ 和 $\text{Auth}_i = H(KU_i \| u_i \| ID_i \| T)$ 。最后, U_i 通过公共信道将消息 $\text{msg}_1 = \{D_{id}, u, \text{Auth}_i, w_i\}$ 发送给服务器 S_j 。

c)服务器 S_j 收到消息 $\text{msg}_1 = \{D_{id}, u, \text{Auth}_i, w_i\}$ 后,随机采样 $e'_j, r'_j \leftarrow \chi_\alpha$,然后,服务器 S_j 计算 $R_s = a \cdot u_i - pk_i$, $X'_u = R_s \cdot s_j$, $T' = \text{mod}_2(X'_u, w_i)$, $ID_i = D_{id} \oplus T'$, $KU'_i = H(ID_i \| s_j)$ 和 $\text{Auth}'_i = H(KU'_i \| u_i \| ID_i \| T')$,随后验证 $\text{Auth}'_i = \text{Auth}_i$,若验证通过,服务器 S_j 计算 $X_j = a \cdot r_j + 2 \cdot e'_j$, $X_s = R_s \cdot r_j$, $w_j = \text{Cha}(X_s)$ 和 $k_j = \text{mod}_2(X_s, w_j)$,利用上述计算值得到两端的共享会话密钥 $sk_j = H(KU'_i \| k_j \| ID_i \| T')$ 。最后服务器 S_j 计算 $\text{Auth}_j = H(sk_j \| u_i \| ID_i \| w_j)$,并通过公共信道发送消息 $\text{msg}_2 = \{X_j, \text{Auth}_j, w_j\}$ 给用户 U_i 。

d)用户 U_i 收到消息 $\text{msg}_2 = \{X_j, \text{Auth}_j, w_j\}$ 后,计算 $X'_s = X_j \cdot r_i$ 和 $k_i = \text{mod}_2(X'_s, w_i)$,利用上述值计算出两端的共享会话密钥 $sk_i = H(KU_i \| k_i \| ID_i \| T)$ 以及 $\text{Auth}'_j = H(sk_i \| u_i \| ID_i \|$

w_j), 并验证 $Auth'_i = Auth_j$, 若验证不通过, 智能卡 SC_i 中止此会话, 否则用户 U_i 和服务器 S_j 得到最终的共享密钥 $sk_i = sk_j$ 。具体的登录认证过程如图3所示。

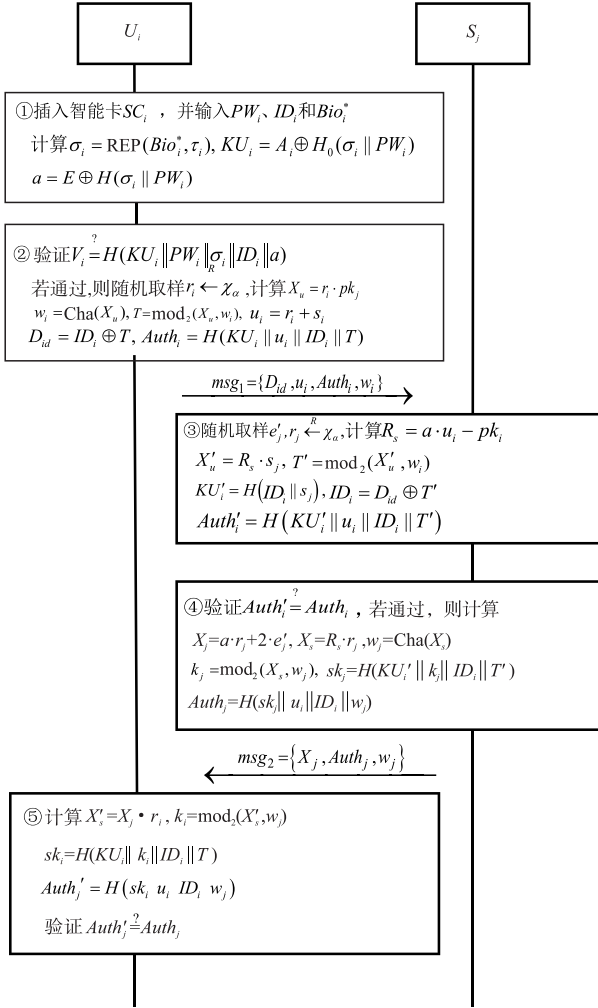


图3 登录与认证阶段

Fig. 3 Login and authentication phase

2.4 更新阶段

当合法用户 U_i 出于某些安全原因想要更新其口令 PW_i 和生物特征 Bio_i , 可以在注册后的任何时间进行更改, 更新阶段的具体步骤如下。

a) $update(ID_i, PW_i, Bio_i) \rightarrow (PW_i^{new}, Bio_i^{new}, V_i^{new})$: 用户 U_i 插入智能卡 SC_i , 输入标识 ID_i 、密码 PW_i 和生物特征 Bio_i , 与登录阶段一样, 智能卡 SC_i 使用模糊提取器函数计算 $\sigma_i = REP(Bio_i^*, \tau_i)$ 以及 $V_i = H(KU_i || PW_i || \sigma_i || ID_i || a)$, 并验证存储的 V' 和 V_i 是否相等。若两者不相等, 立即终止操作, 否则用户 U_i 身份合法, 可以继续更新操作。

b) 用户 U_i 输入新的口令 PW_i^{new} 和生物特征 Bio_i^{new} , 如果用户 U_i 不想更改生物特征, 则仍可以保留旧的生物特征 Bio_i 。智能卡 SC_i 计算 $(\sigma_i^{new}, \tau_i^{new}) = Gen(Bio_i^{new})$, $\sigma_i^{new} = REP(Bio_i^{new}, \tau_i^{new})$, $V_i^{new} = H(KU_i || PW_i^{new} || \sigma_i^{new} || ID_i || a)$, 最后将智能卡中的 V_i 替换成 V_i^{new} 。

2.5 正确性证明

在 U_i 和 S_j 的认证阶段, 正确性条件要求满足 $T = T'$ 和 $K_i = K_j$, 以确保 U_i 和 S_j 双方能够推导出相同的会话密钥, 即 $sk_i = sk_j$ 。下面详细阐述 $T = T'$ 的推导过程, 由于 $K_i = K_j$ 与 $T = T'$ 的推导过程类似, 故在此省略。请注意, T 和 T' 分别由中间变量 X_u 和 X'_u 计算得出。具体来说:

$$X_u = r_i \cdot pk_j =$$

$$r_i \cdot (a \cdot s_j + 2 \cdot e_j) =$$

$$a \cdot r_i \cdot s_j + 2 \cdot e_j \cdot r_i$$

$$(10)$$

$$X'_u = R_s \cdot s_j = (a \cdot u_i - pk_i) \cdot s_j =$$

$$((s_i + r_i) \cdot a - (a \cdot s_i + 2 \cdot e_i)) \cdot s_j =$$

$$(a \cdot r_i - 2 \cdot e_i) \cdot s_j = a \cdot r_i \cdot s_j - 2 \cdot e_i \cdot s_j$$

$$(11)$$

根据式(10)和(11), 可计算出:

$$X_u - X'_u = 2 \cdot (e_j \cdot r_i + e_i \cdot s_j)$$

应用引理1和2, 可得到:

$$|X_u - X'_u| \leq 2 \cdot \sqrt{n} \cdot |e_j| \cdot |r_i| + 2 \cdot \sqrt{n} \cdot |e_i| \cdot |s_j| \leq$$

$$2 \cdot \alpha^3 n^{\frac{5}{2}} + 2 \cdot \alpha^3 n^{\frac{5}{2}} = 4\alpha^3 n^{\frac{5}{2}} \quad (12)$$

由引理2可知 $(\alpha = \omega(\sqrt{\log n}))$ 且 $(n < q)$, 因此可计算出

$$4\alpha^3 n^{\frac{5}{2}} < \frac{q}{8}, \text{ 通过应用引理3, 可得到 } T = \text{mod}_2(X_u, w_i) = \text{mod}_2$$

$$(X'_u, w_j) = T'.$$

3 安全分析

在本章中通过形式化安全分析和非形式化分析来证明所提方案的安全性。

3.1 形式化安全分析

在本节中, 利用 ROR 模型来证明定理1中所提协议对敌手 A 的会话密钥 (sk) 安全性。所提协议涉及两个参与方: U_i 和 S_j 。每一方可能有多个并发实例, 称为预言机, 分别用 Π_U^i 和 Π_S^j 表示 U_i 的第 i 个实例和 S_j 的第 j 个实例, 一个通用实例用 I 表示。在 ROR 模型中, 为体现敌手 A 在现实世界场景中的攻击能力, 敌手 A 被允许发出一系列查询, 如 $send(\cdot)$ 查询、 $execute(\cdot)$ 查询、 $test(\cdot)$ 查询和 $corrupt(\cdot)$ 查询。此外, 抗碰撞单向哈希函数 $H(\cdot)$ 被用作随机预言机。

a) $execute(\Pi_U^i, \Pi_S^j)$: 该查询模拟协议执行过程中的被动攻击, 并返回实体 Π_U^i 和 Π_S^j 之间通信的完整记录。

b) $send(\Pi_U^i, Start)$: 该查询启动协议 Π 的执行。

c) $send(I, m)$: 该查询模拟协议 Π 执行过程中的主动攻击。敌手 A 通过捕获其他合法消息并伪造消息 m , 然后将其发送到实例 I , 随后获得其响应。

d) $reveal(I)$: 该查询模拟会话密钥 sk 泄露攻击。如果实例 I 已接受并生成了会话密钥 sk , 该查询将返回 sk 给敌手 A ; 否则, 返回错误符号 $\perp$ 。

e) $corrupt(\Pi_U^i, a)$: 该查询模拟 Π_U^i 认证因子泄露攻击。敌手 A 可以获取实例 Π_U^i 所拥有的三种认证因子 (智能卡、生物特征和口令) 中的任意两种, 但不能获取所有三种。该查询可以分为以下几种情况: (a) 如果 $a=1$: 返回 U_i 的口令 PW_i 和智能卡 SC_i 参数; (b) 如果 $a=2$: 返回 U_i 的生物特征 Bio_i 和智能卡 SC_i 参数; (c) 如果 $a=3$: 返回 U_i 的口令 PW_i 和生物特征 Bio_i 。

f) $corrupt(I)$: 该查询模拟实例 I 长期密钥的泄露, 返回长期密钥。

g) $test(I)$: 该查询模拟敌手 A 破解会话密钥 sk 语义安全性的能力, 即区分真实密钥和随机密钥的能力。接收到查询后, 进行一次掷硬币操作, 结果为 b 。如果 $b=1$, 返回真实会话密钥 sk ; 否则, 返回与会话密钥 sk 长度相同的随机值。

a) 伙伴。要将两个实例 Π_U^i 和 Π_S^j 视为伙伴, 必须满足以下三个条件: (a) 两者必须都已接受; (b) 会话标识符 (SID) 相同; (c) 它们的伙伴标识符 (PID) 必须相互指向对方。

b) 新鲜性。敌手 A 获取真实会话密钥 sk 的能力。实例 I 被认为是新鲜的, 需满足以下三个条件: (a) 实例 I 已接受并生

成了有效的会话密钥 sk ; (b) 敌手 $\mathcal{A}$ 没有对实例 I 或其伙伴实例发出 $\text{reveal}(\cdot)$ 查询; (c) 敌手 $\mathcal{A}$ 至多调用过一次 $\text{corrupt}(\cdot)$ 查询。

定义 1 语义安全。设 $\text{Adv}_{\mathcal{A}}^{\text{AKE}}(t)$ 为一个在多项式时间 t 内执行的敌手 $\mathcal{A}$ 破坏所提协议的语义安全性以获取 U_i 和 S_j 之间会话密钥 sk 的优势。则 $\text{Adv}_{\mathcal{A}}^{\text{AKE}}(t) = |2 \cdot \text{Prob}[b = b'] - 1|$, 其中 b 和 b' 分别表示“正确”和“猜测”的比特。

定理 1 假设 $\text{Adv}_{\mathcal{A}}^{\text{AKE}}(t)$ 是敌手 $\mathcal{A}$ 在概率多项式时间 t 内成功破解所提协议的语义安全性的概率。令 q_s, q_e, q_h 为敌手 $\mathcal{A}$ 调用 $\text{send}(\cdot)$ 查询、 $\text{execute}(\cdot)$ 查询和 $H(\cdot)$ 查询的次数, 然后

$$\text{Adv}_{\mathcal{A}}^{\text{AKE}}(t) \leq \frac{q_s + q_h^2}{|\mathcal{H}|} + \frac{(q_s + q_e)^2}{2|G|} + 2C' \cdot q_s' + (2 + 4q_h \cdot (q_s + q_e)) \cdot \text{Adv}_{\mathcal{A}}^{\text{RLWE}}(t) \quad (13)$$

其中: C' 和 s' 表示 Zipf 参数; $|\mathcal{H}|$ 表示哈希函数的范围空间; $|G|$ 表示离散高斯分布采样的范围空间。

证明 首先, 本文定义 7 个游戏: $\text{Game}_0, \text{Game}_1, \text{Game}_2, \text{Game}_3, \text{Game}_4, \text{Game}_5, \text{Game}_6$, 以打破会话密钥 sk 的语义安全性, 令 Succ_i 表示敌手 $\mathcal{A}$ 正确猜测 $\text{test}(\cdot)$ 查询中输出比特 b 的事件, 其中 $i = 0, 1, \dots, 6$ 。

Game_0 : 该游戏表示为敌手 $\mathcal{A}$ 对所提方案的真实攻击, 根据定义 1:

$$\text{Adv}_{\mathcal{A}}^{\text{AKE}}(t) = |2 \cdot \text{Prob}[\text{Succ}_0] - 1| \quad (14)$$

Game_1 : 该游戏表示为对所提协议的窃听攻击, 其中敌手 $\mathcal{A}$ 在通信过程中窃听了 U_i 和 S_j 之间传输的消息 $\{D_{id}, u_i, \text{Auth}_i, w_i\}$ 和 $\{X_j, \text{Auth}_j, w_j\}$ 。然后敌手 $\mathcal{A}$ 执行 $\text{execute}(\Pi_U^i, \Pi_S^j)$ 查询, 随后调用 $\text{test}(\cdot)$ 查询和 $\text{reveal}(\cdot)$ 查询, 以验证会话密钥 sk_i 和 sk_j 是否有效。由于 $sk_i = H(KU_i \parallel k_i \parallel ID_i \parallel T \parallel KU_i) = sk_j$, U_i 与 S_j 之间的会话密钥 sk_i 和 sk_j 是使用长期和短期秘密计算的, 所以敌手 $\mathcal{A}$ 计算 sk_i 和 sk_j 是计算上困难的, 且赢得 $\mathcal{G}_i$ 的概率与 $\mathcal{G}_0$ 相同。因此有:

$$\text{Prob}[\text{Succ}_1] = \text{Prob}[\text{Succ}_0] \quad (15)$$

Game_2 : 该游戏与 Game_1 相同, 唯一不同的是如果消息在传输中发生碰撞 ($\{D_{id}, u_i, \text{Auth}_i, w_i\} \parallel \{X_j, \text{Auth}_j, w_j\}$) 或者哈希 $H(\cdot)$ 查询的输出发生碰撞, 则停止游戏。因此, 根据生日悖论, 得到:

$$|\text{Prob}[\text{Succ}_2] - \text{Prob}[\text{Succ}_1]| \leq \frac{q_h^2}{|\mathcal{H}|} + \frac{(q_s + q_e)^2}{2|G|} \quad (16)$$

Game_3 : 该游戏类似于 Game_2 , 不同点在于敌手 $\mathcal{A}$ 在不查询预言机的情况下正确猜测出验证值 Auth_i 和 Auth_j 时, 则将被终止, 因此有:

$$|\text{Prob}[\text{Succ}_3] - \text{Prob}[\text{Succ}_2]| \leq \frac{q_s}{|\mathcal{H}|} \quad (17)$$

Game_4 : 在该游戏中, 模拟会话密钥 sk 在没有查询相应的随机预言机的情况下被猜测出来, 在所提协议中, 会话密钥 $sk_i = H(KU_i \parallel k_i \parallel ID_i \parallel T) = H(KU'_i \parallel k_j \parallel ID_i \parallel T') = sk_j$, 其中 $k_i = \text{mod}_2(X_j \cdot r_i, w_j)$ 和 $k_j = \text{mod}_2(X_s, w_j)$, 这两个值基于 RLWE 问题。如果敌手 $\mathcal{A}$ 正确猜测出会话密钥 sk , 那么就相当于解决了 RLWE 问题。因此可以有:

$$|\text{Prob}[\text{Succ}_4] - \text{Prob}[\text{Succ}_3]| \leq (q_s + q_e) \cdot \text{Adv}_{\mathcal{A}}^{\text{RLWE}}(t) \quad (18)$$

Game_5 : 在该游戏中, 敌手 $\mathcal{A}$ 在提取对应的智能卡 SC_i 参数后尝试猜测口令 PW_i 。在此情况下, 敌手 $\mathcal{A}$ 调用 $\text{corrupt}(\Pi_U^i, 2)$, 根据敌手 $\mathcal{A}$ 能力, 无法进行 $\text{corrupt}(\Pi_U^i, 1)$ 和 $\text{corrupt}(\Pi_U^i, 3)$ 查询, 如果本文限制协议允许的口令输入次数。因此, 基于生日悖论和口令的 Zipf 分布规则, 有

$$|\text{Prob}[\text{Succ}_4] - \text{Prob}[\text{Succ}_3]| \leq C' \cdot q_s' \quad (19)$$

Game_6 : 在该游戏中, 考虑了协议的完美前向安全性。基于新鲜性的定义, 敌手 $\mathcal{A}$ 可以在调用 $\text{test}(\cdot)$ 查询之后, 进行 $\text{corrupt}(\cdot)$ 查询。然后有:

$$|\text{Prob}[\text{Succ}_5] - \text{Prob}[\text{Succ}_4]| \leq 2q_h(q_s + q_e)^2 \cdot \text{Adv}_{\mathcal{A}}^{\text{RLWE}}(t) \quad (20)$$

到目前为止, 敌手 $\mathcal{A}$ 在区分真实会话密钥 sk 和一个相同长度的随机密钥方面的优势为 0, 因此 $\text{Prob}[\text{Succ}_6] = \frac{1}{2}$ 。基于

于 $\text{Game}_0 \sim \text{Game}_6$, 有:

$$\text{Adv}_{\mathcal{A}}^{\text{AKE}}(t) \leq \frac{q_s + q_h^2}{|\mathcal{H}|} + \frac{(q_s + q_e)^2}{2|G|} + 2C' \cdot q_s' + (2 + 4q_h \cdot (q_s + q_e)) \cdot \text{Adv}_{\mathcal{A}}^{\text{RLWE}}(t) \quad (21)$$

3.2 非形式化安全分析

本节是对文中所提方案的非形式化的安全分析。

a) 用户匿名性。在本文所提方案中, 用户 U_i 的身份并不会在公共信道上进行公开的传输, 这能够有效地防止攻击者在通信过程中获取用户的身份信息, 即使攻击者能够获取存储在智能卡 SC_i 中的所有参数, 包括 $\{A_i, V_i, E, H(\cdot)\}$, 并且攻击者截获发送给信道上的消息 $\text{msg}_i = \{D_{id}, u_i, \text{Auth}_i, w_i\}$ 和 $\text{msg}_2 = \{X_j, \text{Auth}_j, w_j\}$; 用户的身份信息 ID_i 仍然安全, 因为 ID_i 在每一次会话过程中都由 U_i 端通过计算 $D_{id} = ID_i \oplus T$ 重新生成, 这种计算方式保证了用户的匿名性和不可追踪性, 达到了维护安全的目的。

b) 特权内部攻击。在注册阶段, U_i 端仅向 S_j 端发送身份标识 ID_i , 而不包含任何与口令或生物特征相关的信息。随后, S_j 端将一张新的智能卡 SC_i 发送给用户 U_i 。在接收到 SC_i 后, U_i 端通过输入只有其本人知晓的口令 PW_i 和生物特征 Bio_i 来激活智能卡 SC_i 。最终, U_i 端获得了已写入新参数的智能卡 SC_i 。通过检查存储在 SC_i 中的所有参数可以发现, 口令 PW_i 并未以明文形式出现, 而是利用单向函数进行了安全保护; 同样, 攻击者也极难恢复用户的生物特征。因此, 该协议能够有效抵御特权内部攻击。

c) 重放攻击。假设攻击者截获了上一次会话中的 msg_1 , 也就是 $\{D_{id}, u_i, \text{Auth}_i, w_i\}$ 等信息并试图进行重放攻击, 然而, 在用户端, 每次的 U_i 是随机选取生成的, 因此在每次的会话中 Auth_i 都会变化, 重放的 msg_1 无法通过对 Auth_i 的验证。同样地, 假设攻击者截获了上次会话中的 $\text{msg}_2 = \{X_j, \text{Auth}_j, w_j\}$ 进行重放攻击, 其中 Auth_i 在每轮会话中都会变化, 因此攻击者无法通过对 Auth_i 的验证从而实现重放攻击。因此, 所提方案能够有效抵抗重放攻击。

d) 密钥泄露伪装攻击。假设 U_i 端和 S_j 端的长期私钥 s_i 和 s_j 均已泄露, 那么攻击者可能会尝试伪装成任何一方来与对方建立连接, 从而窃取数据或者恶意操作。但是, 在本方案中, 如果攻击者尝试伪装成 U_i 端, 为了伪造一个有效的登录请求, 他必须能够生成 $\text{Auth}_i = H(KU_i \parallel u_i \parallel ID_i \parallel T)$, 其中 T 在 U_i 端和 S_j 端的计算方式是不同的, 在 U_i 端, $T = \text{mod}_2(X_u, w_i)$, 其中 $X_u = r_j \cdot pk_j$, 而在 S_j 端, $T' = \text{mod}_2(X'_u, w_i)$, 其中 $X'_u = R_s \cdot s_j$ 。在不访问部分关键参数的情况下, 攻击者无法重建参数 T , 因此无法伪装成 U_i 。同样地, 攻击者无法伪造消息 Auth_i , 因此无法冒充 S_j 端, 所以即使长期私钥被泄露, 该方案仍能抵御伪装攻击。

e) 临时密钥泄露攻击。在所提方案中, 会话密钥在 U_i 端与 S_j 端完成双向认证后建立, 其计算方式为 $sk_i = H(KU_i \parallel k_i \parallel ID_i \parallel T)$, 即使攻击者获取了所有临时信息 (包括 r_i, e'_j, r_j), 并能推导出 k_i 和 T , 计算会话密钥 sk 仍然需要知道 $\{KU_i, ID_i\}$, 而这些信息无法从长期私钥 s_i 或 s_j 中推导得到。因此, 所提方案能够抵抗临时秘密泄露攻击。

f) 中间人攻击。假设攻击者在公共信道上拦截了 U_i 端与 S_j 端之间交换的消息,包括 $\{D_{id}, u_i, Auth_i, w_i\}$ 和 $\{X_j, Auth_j, w_j\}$,为了实施中间人攻击,攻击者必须伪造这些消息以通过双向认证。然而,正如之前分析所示,本方案已具备抵御重放攻击和伪装攻击的能力,因此攻击者无法成功完成认证流程。综上,该方案能够抵御中间人攻击。

g) 双向认证。在所提方案中, U_i 端首先向 S_j 端发送消息 $Auth_i = H(KU_i \parallel u_i \parallel ID_i \parallel T)$, S_j 端通过比较收到的 $Auth_i$ 与本地计算出的 $Auth'_i$ 是否一致来验证 U_i 端的身份;若两者相等,则 U_i 端通过 S_j 端的认证。随后, S_j 端回送消息 $Auth_j = H(sk_j \parallel u_i \parallel ID_i \parallel w_j)$ 。 U_i 端收到后,检查 $Auth_j$ 是否与其本地计算值 $Auth'_j$ 匹配;若验证成功,则 S_j 端通过 U_i 的认证。因此,该方案实现了可靠的双向认证。

h) 完美前向保密。假设 U_i 端与 S_j 端的长期私钥已被泄露,攻击者已经掌握用户的口令 PW_i 、生物特征 Bio_i 、智能卡 SC_i ,以及 U_i 端与 S_j 端之间交换的全部消息 $\{D_{id}, u_i, Auth_i, w_i\}$ 和 $\{X_j, Auth_j, w_j\}$ 。利用这些信息,攻击者可计算 $X_u = r_i \cdot pk_j$,进而推导出 $T = \text{mod}_2(X_u, w_i)$ 。

然而基于这些信息,攻击者为了重构会话密钥 $sk_i = H(KU_i \parallel k_i \parallel ID_i \parallel T)$ 必须获得 k_i ,但由于 $k_i = \text{mod}_2(X'_s, w_j)$,恢复 k_i 等价于求解 RLWE 问题,而 RLWE 问题在多项式时间内是计算困难的。所以,攻击者无法推导出会话密钥 sk_i 。即使在长期密钥泄露、全部参数暴露的强对抗模型下,所提方案仍可实现完美前向保密。即使同时拥有智能卡和生物数据,没有正确的口令也无法计算出 KU_i 。

i) 三因素安全。按照三因子认证模型,攻击者最多只能同时拿到智能卡、口令、生物特征中的任意两项。会话密钥 sk_i 的关键参数 KU_i 定义为 $KU_i = A_i \oplus H_0(\sigma_i \parallel PW_i)$ 。

以下分析表明,在任意两项泄露的情况下,攻击者都无法计算出 KU_i :

情况 1:口令 PW_i + 智能卡 SC_i

即使攻击者拿到 PW_i 并提取智能卡 SC_i 中的所有参数,没有生物特征 Bio_i ,仍无法求出 KU_i 。

情况 2:口令 PW_i + 生物特征 Bio_i

若攻击者同时掌握口令 PW_i 与生物特征 Bio_i ,但缺少智能卡 SC_i 中的 A_i 等关键值,同样无法推导出 KU_i 。

情况 3:智能卡 SC_i + 生物特征 Bio_i

即使同时拥有智能卡 SC_i 和生物特征 Bio_i ,没有正确的口令 PW_i 也无法计算出 KU_i 。

因此,只要三个因素没有同时被攻破,会话密钥就始终安全,方案满足三因素安全性。

4 实验分析

本章分析了本文协议的计算耗时,并与对比协议^[22, 29-31, 33]进行比较。分别设计了多个实验来模拟在不同算力的通信环境下不同协议的差别,计算了不同方案的通信开销和存储开销。

4.1 实验设置

在实验部分,本文采用了树莓派和虚拟机作为测试平台,以评估不同协议的性能。具体配置如下:树莓派搭载了 ARM 1.2 GHz 处理器和 1 GB 内存,而虚拟机则配备了 Intel i7-6700HQ 1.9 GHz 处理器和 16 GB 内存。为了量化各协议在用户(U_i)和服务器(S_j)两端的计算效率,本文定义了 C_{total} 来表示总的计算时间。为了减少偶然误差,本文对每个协议进行了 10 次独立运行,并计算了平均值以得出结果。在实验中,本文选择了 SHA256 哈希函数,其输出为 256 bit, R_q 中每个元素占

$2^{32}-1$ bit,参数 $n=512$ bit, $q=12\ 289$,私钥占 512 bit,公钥占 512 bit,随机数占 32 bit,时间戳占 64 bit,身份信息占 96 bit。表 2 详细列出了在树莓派上执行协议时,各种操作所需的时间。这些数据为本文提供了对不同操作计算复杂度的直观理解,并有助于评估所提出协议在资源受限设备上的性能表现。

表 2 各种操作运行时间

Tab. 2 Various operation time

nations	descriptions	Raspberry Pi/ms
T_{sam}	环上采样	0.370
T_m	多项式乘法	11.262
T_h	哈希	0.162
U_i	多项式加减法	0.78
U_i	环上标量乘	0.539
U_i	信号函数	1.031

如表 2 所示,本文分析了在两个 1.2 GHz 配置的树莓派上,不同操作的耗时情况。

4.2 实验 1

为了模拟物联网环境中通信双方的算力不等的情景,本文分析了在 0.6 GHz 频率的树莓派和 1.9 GHz 频率的服务器下不同协议的耗时详情。从表 3 中可以看出,本文协议在用户(U_i)和服务器(S_j)两端的操作次数和耗时均显示出了显著的优势。具体来说,协议在 U_i 端仅需执行 1 次采样(T_{sam})、2 次多项式乘法(T_m)、6 次哈希(T_h)、1 次多项式加减法(T_a)和 1 次信号函数(T_c),总耗时约为 52.975 ms。相比之下,文献[29]的协议在 U_i 端操作较多,需要执行 2 次采样、3 次多项式乘法、8 次哈希、1 次加法、1 次环上标量乘和 1 次信号函数,总耗时约为 67.085 ms。文献[30]的协议在 U_i 端则需要执行 3 次采样、3 次多项式乘法、8 次哈希、3 次多项式加减法以及 3 次环上标量乘,其总耗时仍然达到了 66.213 ms。而文献[22]的协议在 U_i 端的操作包括 3 次采样、3 次多项式乘法、1 次哈希、3 次多项式加减法和 3 次环上标量乘,总耗时达 73.965 ms。文献[33]的协议在 U_i 端的操作包括 2 次采样、3 次多项式乘法、6 次哈希、3 次多项式加减法、3 次环上标量乘和 2 次信号函数,总耗时达 70.107 ms。文献[31]的协议在 U_i 端的操作包括 2 次采样、3 次多项式乘法、6 次哈希和 1 次多项式加减法,总耗时达 66.391 ms。

在服务器端,本文协议的操作同样简洁高效,仅包括 2 次采样、4 次多项式乘法、4 次哈希、2 次多项式加法和 1 次信号函数,总耗时约为 11.86 ms。相比之下,文献[29]的协议在 S_j 端执行的操作有 2 次采样、3 次多项式乘法、4 次哈希、1 次加法、1 次环上标量乘和 1 次信号函数,总耗时约为 7.289 ms。文献[30]的协议在 S_j 端操作较少,需要执行 1 次采样、2 次多项式乘法、6 次哈希、2 次多项式加减法、2 次环上标量乘以及 1 次信号函数,其总耗时达到了 3.632 ms。而文献[22]的协议在 S_j 端的操作包括 4 次采样、3 次多项式乘法、1 次哈希、3 次多项式加减法、3 次环上标量乘和 1 次信号函数,总耗时达 4.804 ms。文献[33]的协议在 S_j 端的操作包括 2 次采样、3 次多项式乘法、6 次哈希、3 次多项式加减法、3 次环上标量乘和 2 次信号函数,总耗时达 5.635 ms。文献[31]的协议在 S_j 端的操作包括 2 次采样、3 次多项式乘法、3 次哈希和 2 次多项式加减法,总耗时达 5.93 ms。

综合用户端和服务器的总耗时,本文协议的总耗时为 64.835 ms,是所有协议中最短的。这表明,本文协议在减轻 U_i 端计算负担的同时,也保持了较高的计算效率。通过表 3 的数据可以看出,本文协议在计算效率方面均表现出色,尤其是在当前频差较大的实验环境下,使其成为在资源受限环境中实现高效多因素认证的理想选择。

表 3 不同协议的操作耗时
Tab. 3 Operation time of different protocols

协议	U_i	S_j	C_{total}
文献[22]	$3T_{sam}+3T_m+T_h+3T_a+3T_s=73.965$	$4T_{sam}+3T_m+T_h+3T_a+3T_s+T_c=4.804$	78.769
文献[29]	$2T_{sam}+3T_m+8T_h+T_a+T_s+T_c=67.085$	$2T_{sam}+3T_m+4T_h+T_a+T_s+T_c=7.289$	74.374
文献[30]	$3T_{sam}+3T_m+8T_h+3T_a+3T_s=66.213$	$T_{sam}+2T_m+6T_h+2T_a+2T_s+T_c=3.632$	69.845
文献[33]	$2T_{sam}+3T_m+6T_h+3T_{sam}+3T_{sam}+2T_{sam}=70.107$	$2T_{sam}+3T_m+6T_h+3T_{sam}+3T_{sam}+2T_{sam}=5.635$	75.742
文献[31]	$2T_{sam}+3T_m+6T_h+T_{sam}=66.391$	$3T_{sam}+3T_m+3T_h+2T_{sam}=5.93$	72.321
本文协议	$T_{sam}+2T_m+6T_h+T_a+T_c=52.975$	$2T_{sam}+4T_m+4T_h+2T_a+T_c=11.86$	64.835

4.3 实验 2

本文测量了两个树莓派之间在不同频率下本文协议和对比协议^[22, 29-31, 33]的计算时间,包括 0.6/1.2、0.7/1.2、0.8/1.2、0.9/1.2、1.0/1.2、1.2/1.2 这 6 种频率差。分为两种情况:一种是仅 U_i 端,即算力有限的一端不同协议之间计算时间的对比,如图 4 所示;另一种是总计算时间,即不同协议之间通信双方的总时间,结果如图 5 所示,从图中可以看出,无论是算力低的一方还是双方的总计算时间,随着频率差的增大,本文协议耗时明显短于对比协议^[22, 29-31, 33]。

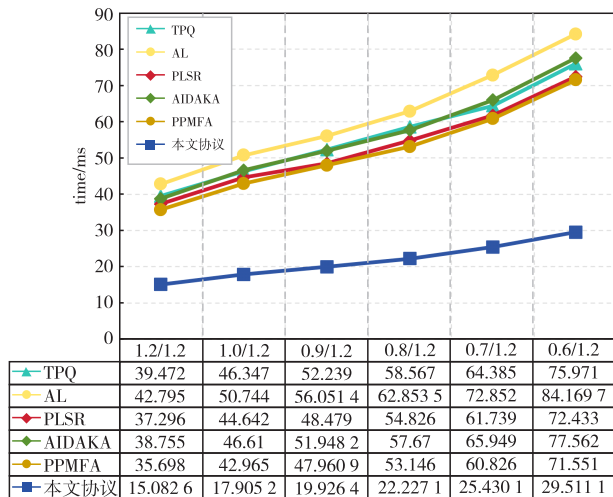


图 4 实验 2 中不同频率不同协议间 U_i 端计算时间对比

Fig. 4 Comparison of U_i calculation time among different frequencies and protocols in experiment 2

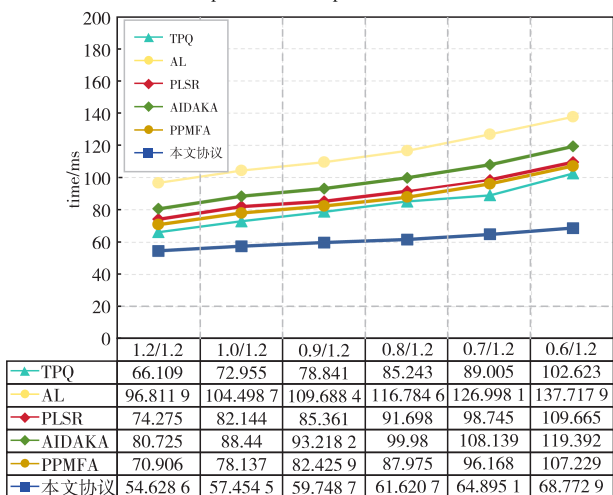


图 5 实验 2 中不同频率不同协议间总计算时间对比

Fig. 5 Comparison of total computation time among different frequencies and protocols in experiment 2

4.4 实验 3

在这部分,本文进一步拉大了双方的 CPU 频率差距,这里使用树莓派和虚拟机进行通信。本文检测了以下频率组合:1.2/1.9、1.0/1.9、0.9/1.9、0.8/1.9、0.7/1.9 和 0.6/1.9。本文比较了以上这几组频率差下不同方案之间的耗时情况,如图

6 所示,本文有以下发现。当通信双方的 CPU 频率差越大时,本文协议的优势更加明显。

4.5 通信开销

在所提协议的登录和认证阶段,用户 U_i 向服务器 S_j 发送消息 $msg_1 = \{D_{id}, U_i, Auth_i, w_i\}$ 。作为响应,服务器 S_j 回复用户 U_i $msg_2 = \{X_j, Auth_j, w_j\}$ 。所提方案的总通信开销为 $(96 + 512 \times 32 + 256 + 512 + 512 \times 32 + 256 + 512) = 34\ 400$ bit。

在文献[22]中,用户 U_i 向服务器 S_j 发送消息 $\{p_i\}$,作为响应,服务器 S_j 回复用户 U_i 消息 $\{p_j, w_j, e_p\}$ 。因此,文献[22]的总通信开销为 $(512 \times 32 + 512 \times 32 + 512 \times 32) = 49\ 664$ bit。

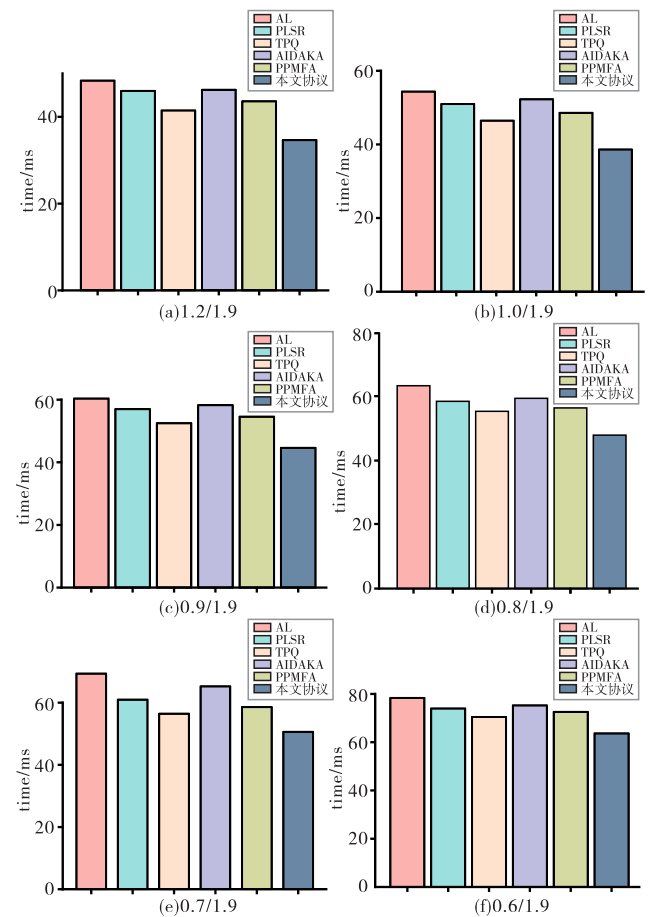


图 6 实验 3 中不同频率不同协议间总计算时间对比

Fig. 6 Comparison of total computation time among different frequencies and protocols in experiment 3

在文献[29]中,用户 U_i 向服务器 S_j 发送消息 $\{X_u, G_u, G_3, C_u, T_1\}$,作为响应,服务器 S_j 回复用户 U_i 消息 $\{G_2, C_s, X_s, T_2\}$ 。因此,文献[29]总通信开销为 $(512 \times 32 + 256 + 256 + 512 + 64 + 256 + 512 + 512 \times 32 + 64) = 34\ 688$ bit。

在文献[30]中,用户 U_i 向服务器 S_j 发送消息 $\{PID_i, x_i, T_i, \Sigma_i\}$,作为响应,服务器 S_j 回复用户 U_i 消息 $\{w_j, \Sigma_j\}$ 。因此,文献[30]的总通信开销为 $(96 + 512 \times 32 + 64 + 256 + 512 + 256) = 18\ 873$ bit。

在文献[33]中,用户 U_i 向服务器 S_j 发送消息,作为响应,

服务器 S_j 回复用户 U_i 消息 $\{\sigma'_j, x_j, z_j\}$ 。因此,文献[33]的总通信开销为 $(256+256+512 \times 32+512+512+512 \times 32+256)=34\ 560$ bit。

在文献[31]中,用户 U_i 向服务器 S_j 发送消息 $\{b_i, t_1, r_i, \text{auth}\}$, 作为响应,服务器 S_j 回复用户 U_i 消息 $\{b_j, r_j, t_3, \text{auth}_1\}$ 。因此,文献[31]的总通信开销为 $(512 \times 32+64+512 \times 32+512+512 \times 32+512 \times 32+64+256)=66\ 432$ bit。

表4对所提协议与文献[22, 29~31, 33]的通信开销进行了比较研究。所提协议的通信开销低于大部分对比协议^[22, 29~31, 33],虽然文献[30]通信开销少于所提协议,但其未能保证协议的完美前向安全性,并且容易受到密钥泄露伪装、重放以及设备丢失攻击。相比之下,所提协议以略微增加通信成本为代价,提升了协议的安全性,以达到安全性和性能的整体权衡。

表4 通信开销对比

Tab. 4 Communication overhead comparison

协议	通信开销/bit
文献[22]	49 664
文献[29]	34 688
文献[30]	18 873
文献[33]	34 560
文献[31]	66 432
本文协议	34 400

4.6 存储开销

存储开销表示在用户端(U_i)和服务器端(S_j)完成认证过程所需的存储空间。在所提方案中,用户端需存储的参数包括: $\{A_i, V_i, E\}$, 所以用户端的存储开销为 $(256+256+256)=768$ bit。服务器端需存储的参数包括: $\{KU_i, H(\cdot)\}$, 所以服务器端的存储开销为 $(256+256+32)=544$ bit。

在文献[22]中,用户端需存储的参数包括: $\{p_i, s_i\}$, 所以用户端的存储开销为 $(512+512)=1\ 024$ bit。服务器端需存储的参数包括: $\{p_j, s_j\}$, 所以服务器端的存储开销为 $(512+512)=1\ 024$ bit。

在文献[29]中,用户端需存储的参数包括: $\{G'_2, \alpha_{v_i}^*, G_v, SK'\}$, 所以用户端的存储开销为 $(256+256+256+256)=1\ 024$ bit。服务器端需存储的参数包括: $\{G_1, SK\}$, 所以服务器端的存储开销为 $(256+256)=512$ bit。

在文献[30]中,用户端需存储的参数包括: $\{A_i, PID_i, V_i, sk_i\}$, 所以用户端的存储开销为 $(256+96+256+256)=864$ bit。服务器端需存储的参数包括: $\{KU_i, sk_j\}$, 所以服务器端的存储开销为 $(256+256)=512$ bit。

在文献[33]中,用户端需存储的参数包括: $\{r_i, f_i, SK_i\}$, 所以用户端的存储开销为 $(256+256+256)=768$ bit。服务器端需存储的参数包括: $\{r_j, f_j, SK_j\}$, 所以服务器端的存储开销为 $(256+256+256)=768$ bit。

在文献[31]中,用户端需存储的参数包括: $\{V_1, V_2, P_u, TID_j, SK_i\}$, 所以用户端的存储开销为 $(256+256+96+256+256)=1\ 120$ bit。服务器端需存储的参数包括: $\{TID_i^*, TPW_i, ID_j, SK_j\}$, 所以服务器端的存储开销为 $(256+256+96+256)=864$ bit。

表5对所提协议与文献[22, 29~31, 33]的存储开销进行了比较研究。所提协议的存储开销均低于文献[22, 29~31, 33]。

表5 存储开销对比

Tab. 5 Storage overhead comparison

协议	存储开销/bit
文献[22]	2 048
文献[29]	1 536
文献[30]	1 376
文献[33]	1 536
文献[31]	1 984
本文协议	1 312

5 结束语

本文提出了一种创新的基于格的轻量级多因素认证密钥交换协议,该协议旨在有效抵御量子计算对传统密码体系的潜在威胁,并特别适用于物联网环境中资源受限设备的高效安全需求。通过一系列严格的实验评估,本文验证了该协议在计算效率方面的显著优势。实验结果表明,与现有基于格的方案相比,该机制在用户端和服务端端的计算时间显著减少,在资源受限设备环境中显著提升了数据传输的效率。此外,通过严格的安全性分析,本文证明了该协议在理论上和实践中均能够提供充分的安全保障。

未来的研究方向将聚焦于进一步优化算法性能,以期在保证安全性的前提下,进一步降低计算复杂度和通信开销。计划将该机制与现有的后量子密码算法进行集成与优化,以确保在后量子环境下区块链数据传输的安全性和可靠性。此外,探索该机制在更广泛的物联网应用场景中的可行性与适应性,如智能交通、远程医疗、智能家居等,将是未来工作的重点。通过持续的研究和探索,本工作预期将为构建安全、高效、可靠的基于格的多因素认证密钥交换协议作出重要贡献,并为后量子密码学的发展提供新的思路 and 方向。期望通过这些努力,为后量子时代的区块链数据传输提供更为完善的解决方案,从而在保障信息安全的同时,推动相关技术在更广泛领域的应用。

总之,本文提出的基于格的轻量级多因素认证密钥交换协议,在抵御量子计算威胁和满足物联网安全需求方面展现出巨大潜力。未来的工作将进一步验证和拓展应用范围,为后量子密码学领域提供坚实的理论基础和实践指导。

参考文献:

- [1] Alwarafy A, Al-Thelaya K A, Abdallah M, *et al.* A survey on security and privacy issues in edge-computing-assisted Internet of Things [J]. *IEEE Internet of Things Journal*, 2021, 8(6): 4004-4022.
- [2] Khan S, Lee W K, Hwang S O. Scalable and efficient hardware architectures for authenticated encryption in IoT applications [J]. *IEEE Internet of Things Journal*, 2021, 8(14): 11260-11275.
- [3] Yu Guosong, Li Qiong, Mao Haokun, *et al.* A multi-scenario authenticated key exchange scheme with forward secrecy for fog-enabled VANETs [J]. *IEEE Trans on Vehicular Technology*, 2025, 74(1): 831-846.
- [4] 徐渊. 基于移动端协助的硬口令认证密钥交换协议 [J]. *计算机应用研究*, 2020, 37(7): 2108-2111. (Xu Yuan. Hardened password-authenticated key exchange protocol based on mobile phone assistance [J]. *Application Research of Computers*, 2020, 37(7): 2108-2111.)
- [5] Han Yunxia, Xu Chunxiang, Jiang Changsong, *et al.* A secure two-factor authentication key exchange scheme [J]. *IEEE Trans on Dependable and Secure Computing*, 2024, 21(6): 5681-5693.
- [6] Zhang Yunru, He Debiao, Vijayakumar P, *et al.* SAPFS: an efficient symmetric-key authentication key agreement scheme with perfect forward secrecy for industrial Internet of Things [J]. *IEEE Internet of Things Journal*, 2023, 10(11): 9716-9726.
- [7] Wu Yapeng, Guo Hua, Han Yiran, *et al.* A security-enhanced authentication and key agreement protocol in smart grid [J]. *IEEE Trans on Industrial Informatics*, 2024, 20(9): 11449-11457.
- [8] Zhang Shiwen, Yan Ziwei, Liang Wei, *et al.* BAKA: biometric authentication and key agreement scheme based on fuzzy extractor for wireless body area networks [J]. *IEEE Internet of Things Journal*, 2024, 11(3): 5118-5128.
- [9] Yu Liying, Wu Wen, Mei Lin. A lightweight cross-layer mutual authentication with key agreement protocol for IIoT [J]. *IEEE Internet of Things Journal*, 2025, 12(6): 7051-7066.

- [10] Han J. CNN-based multi-factor authentication system for mobile devices using faces and passwords [J]. *Applied Sciences*, 2024, 14(12): 5019.
- [11] Segkoulis T, Limnietis K. Enhancing multi-factor authentication for mobile devices through cryptographic zero-knowledge protocols [J]. *Electronics*, 2025, 14(9): 1846.
- [12] Lee H, Ryu J. Physical-unclonable-function-based secure and anonymous user authentication for smart homes [J]. *IEEE Access*, 2024, 12: 172483-172498.
- [13] Wu Yishan, Pang Mengxue, Ma Jianqiang, *et al.* An identity management scheme based on multi-factor authentication and dynamic trust evaluation for telemedicine [J]. *Sensors*, 2025, 25(7): 2118.
- [14] Alshehri H. Developing multi-factor authentication and biometric verification protocols for enhancing data security in IoT healthcare devices [C]//Proc of the 17th International Conference on Computer and Automation Engineering. Piscataway, NJ: IEEE Press, 2025: 367-373.
- [15] Le T V, Yang M H, Mahmood K, *et al.* An enhanced multi-factor device authentication protocol in IoT healthcare environment [J]. *IEEE Trans on Network Science and Engineering*, 2025, 12(2): 571-583.
- [16] Qiu Shuming, Wang Ding, Xu Guoai, *et al.* Practical and provably secure three-factor authentication protocol based on extended chaotic-maps for mobile lightweight devices [J]. *IEEE Trans on Dependable and Secure Computing*, 2022, 19(2): 1338-1351.
- [17] Rafique F, Obaidat M S, Mahmood K, *et al.* An efficient and provably secure certificateless protocol for industrial Internet of Things [J]. *IEEE Trans on Industrial Informatics*, 2022, 18(11): 8039-8046.
- [18] Han Yiran, Guo Hua, Liu Jianwei, *et al.* An enhanced multifactor authentication and key agreement protocol in industrial Internet of Things [J]. *IEEE Internet of Things Journal*, 2024, 11(9): 16243-16254.
- [19] Zou Shihong, Cao Qiang, Lu Ruichao, *et al.* A robust and effective 3-factor authentication protocol for smart factory in IIoT [J]. *Computer Communications*, 2024, 220: 81-93.
- [20] 杨昱坤, 肖为恩, 梁博轩, 等. 面向物联网场景的动态三因素认证密钥协商协议 [J]. *信息网络安全*, 2025, 25(9): 1407-1417. (Yang Yukun, Xiao Weien, Liang Boxuan, *et al.* Dynamic three-factor authentication key agreement protocol for IoT scenarios [J]. *Netinfo Security*, 2025, 25(9): 1407-1417.)
- [21] Micciancio D, Regev O. Lattice-based cryptography [M]//Post-Quantum Cryptography. Berlin: Springer, 2009: 147-191.
- [22] Gao Xinwei, Ding Jintai, Li Lin, *et al.* Practical randomized RLWE-based key exchange against signal leakage attack [J]. *IEEE Trans on Computers*, 2018, 67(11): 1584-1593.
- [23] Feng Qi, He Debiao, Zeadally S, *et al.* Ideal lattice-based anonymous authentication protocol for mobile devices [J]. *IEEE Systems Journal*, 2019, 13(3): 2775-2785.
- [24] Dabra V, Bala A, Kumari S. LBA-PAKE: lattice-based anonymous password authenticated key exchange for mobile devices [J]. *IEEE Systems Journal*, 2021, 15(4): 5067-5077.
- [25] Wang Qingxuan, Wang Ding, Cheng Chi, *et al.* Quantum2FA: efficient quantum-resistant two-factor authentication scheme for mobile devices [J]. *IEEE Trans on Dependable and Secure Computing*, 2023, 20(1): 193-208.
- [26] Alkim E, Ducas L, Pöppelmann T, *et al.* Post-quantum key exchange—a new hope [C]//Proc of the 25th USENIX security Symposium. Berkeley, CA: USENIX Association, 2016: 327-343.
- [27] Qin Yue, Ding Ruoyu, Cheng Chi, *et al.* Light the signal: optimization of signal leakage attacks against LWE-based key exchange [C]//Proc of European Symposium on Research in Computer Security. Cham: Springer, 2022: 677-697.
- [28] Ding Ruoyu, Cheng Chi, Qin Yue. Further analysis and improvements of a lattice-based anonymous PAKE scheme [J]. *IEEE Systems Journal*, 2022, 16(3): 5035-5043.
- [29] Dharminder D, Reddy C B, Das A K, *et al.* Post-quantum lattice-based secure reconciliation enabled key agreement protocol for IoT [J]. *IEEE Internet of Things Journal*, 2023, 10(3): 2680-2692.
- [30] Pursharthi K, Mishra D. Towards post-quantum authenticated key agreement scheme for mobile devices [J]. *Journal of Information Security and Applications*, 2024, 82: 103754.
- [31] Chen Xiao, Wang Baocheng, Li Haibin. A privacy-preserving multi-factor authentication scheme for cloud-assisted IoMT with post-quantum security [J]. *Journal of Information Security and Applications*, 2024, 81: 103708.
- [32] Liu Gao, Li Hao, Le Junqing, *et al.* LRPCA: lattice-based robust and conditional privacy-preserving authentication for VANETs [J]. *IEEE Trans on Vehicular Technology*, 2025, 74(3): 4698-4712.
- [33] 倪亮, 刘笑颜, 谷兵珂, 等. 适用于智能医疗的匿名基于身份的认证密钥协商协议 [J]. *计算机应用研究*, 2025, 42(1): 282-287. (Ni Liang, Liu Xiaoyan, Gu Bingke, *et al.* Anonymous identity-based authenticated key agreement protocol for smart healthcare [J]. *Application Research of Computers*, 2025, 42(1): 282-287.)
- [34] Liu Gao, Li Weiyang, Yuan Chengsheng, *et al.* LBRKA: lattice-based robust authenticated key agreement for VANETs [J]. *IEEE Trans on Vehicular Technology*, 2025, 74(4): 6533-6547.